

M5 – Configuración Segura y Registro de Eventos

Objetivo: Aprender las mejores prácticas de configuración segura en aplicaciones web y la importancia del registro y monitoreo de eventos de seguridad.

José Picón

INTRODUCCIÓN A LA PROTECCIÓN DE DATOS SENSIBLES

¿Qué son los datos sensibles?

Información confidencial que debe ser protegida contra accesos no autorizados.

Ejemplos:

- ❖ **Datos personales:** Nombre, dirección, teléfono.
- ❖ **Credenciales:** Contraseñas, tokens de sesión.
- ❖ **Datos financieros:** Tarjetas de crédito, cuentas bancarias.

Principales riesgos

- Exposición de datos sin cifrado.
- Fugas de información en tráfico de red.
- Almacenamiento inseguro en bases de datos.

Métodos de protección

- Cifrado de datos (AES, RSA).
- Transmisión segura (TLS).
- Control de acceso basado en roles (RBAC) y atributos (ABAC)



INTRODUCCIÓN A LA PROTECCIÓN DE DATOS SENSIBLES

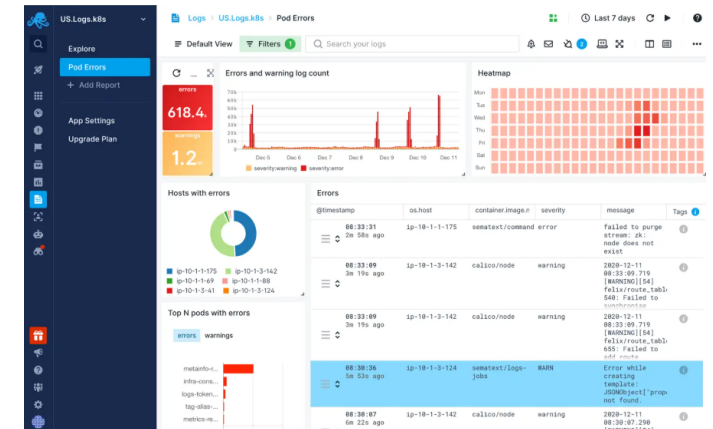
Introducción a la Configuración Segura y Registro de Eventos

¿Por qué es importante una configuración segura?

- Reduce riesgos de ataques por errores de configuración.
- Protege contra amenazas como inyecciones, XSS y acceso no autorizado.

Importancia del registro de eventos (*Logging & Monitoring*)

- Detecta intentos de ataque en tiempo real.
- Permite auditoría y análisis forense de incidentes.



CONTENT SECURITY POLICY (CSP)



¿Qué es Content Security Policy (CSP)?

Definición

- 0 Mecanismo de seguridad que restringe qué contenido puede ser cargado en una página web.
- 0 Protege contra Cross-Site Scripting (XSS), inyecciones de código y ataques de Clickjacking.

Ejemplo de ataque XSS bloqueado por CSP

- 0 Sin CSP:

```
<script>alert('Hacked!')</script>
```

- 0 Con CSP:

```
Content-Security-Policy: script-src 'self'
```

CONTENT SECURITY POLICY (CSP)

Implementación de CSP

Ejemplo de cabecera CSP básica

Content-Security-Policy: default-src 'self'; script-src 'self' https://apis.google.com

- Solo permite cargar recursos desde el mismo dominio ('self').
- Permite scripts solo desde fuentes autorizadas.

Modos de implementación

- **Monitor Mode:** Content-Security-Policy-Report-Only (*Prueba sin bloquear*).
- **Strict Mode:** Content-Security-Policy (*Bloquea todo lo no permitido*).

Buenas prácticas

- No usar **unsafe-inline** (*permite scripts inline*) ni **unsafe-eval** (*permite el uso de eval()*).
- Limitar el uso de fuentes externas (*permitir solo las necesarias: principio de menor privilegio*)



ACTIVIDAD

M5-A1-Implementación y Evaluación de Content Security Policy (CSP)

Tema: Protección contra XSS e inyección de scripts

Objetivo: Aplicar una Content Security Policy (CSP) restrictiva y evaluar su impacto

HTTP STRICT TRANSPORT SECURITY (HSTS)



¿Qué es HSTS y cómo funciona?

Definición

- HSTS (**HTTP Strict Transport Security**) obliga a los navegadores a usar **solo HTTPS** en un sitio web.

Beneficios

- Previene **ataques de downgrade a HTTP**.
- Protege contra **hijacking de cookies y MITM**.

Ejemplo de configuración HSTS

Strict-Transport-Security: max-age=31536000; includeSubDomains; preload

- **max-age=31536000**: Mantiene HSTS activo por un año.
- **includeSubDomains**: Aplica a todos los subdominios.
- **preload**: Permite incluir el sitio en la lista HSTS de navegadores, por lo que los navegadores (como Chrome, Firefox, Safari, Edge, etc.) forzarán el uso de HTTPS desde la primera conexión, incluso antes de que el usuario haya visitado el sitio una sola vez.



**HTTP STRICT
TRANSPORT
SECURITY
(HSTS)**

ACTIVIDAD

M5-A2-Implementación de HTTP Strict Transport Security (HSTS)

Tema: Protección contra ataques MITM

Objetivo: Configurar HSTS para forzar HTTPS y prevenir ataques de degradación a HTTP

SECURITY MISCONFIGURATION

¿Qué es Security Misconfiguration?

Definición

- 0 Errores en la configuración de seguridad de servidores, bases de datos y aplicaciones web.

Ejemplos de configuraciones inseguras

- 0 Consolas de administración accesibles desde internet.
- 0 Directorios abiertos o accesibles sin autenticación.
- 0 Uso de contraseñas predeterminadas en bases de datos.

SECURITY MISCONFIGURATION

Ejemplo de Ataque por Configuración Incorrecta

Escenario

- Un servidor web tiene habilitado el directorio `/admin/` sin autenticación.
- Un atacante accede a `/admin/config.php` y obtiene credenciales de la base de datos.

Consecuencias

- Robo de datos.
- Modificación de configuraciones críticas.

Mitigación

- Restringir acceso con firewalls y autenticación.
- Eliminar archivos innecesarios en producción.
- Realizar escaneos de seguridad periódicos.

SECURITY MISCONFIGURATION

Mejores Prácticas para Configuración Segura

Principios clave

- **Seguridad por defecto:** No dejar configuraciones abiertas.
- **Principio de menor privilegio:** No otorgar más permisos de los necesarios.
- **Automatización de configuraciones seguras:** Uso de herramientas como Ansible o Terraform.

Herramientas recomendadas

- **OWASP ZAP** para pruebas de seguridad web.
- **Nmap** para identificar servicios abiertos.
- **Lynis** para auditoría de servidores Linux.





ACTIVIDAD

M5-A3-Identificación y Corrección de Security Misconfiguration

Tema: Configuración segura en servidores y aplicaciones web

Objetivo: Detectar configuraciones inseguras en un servidor web y corregirlas

LOGGING & MONITORING

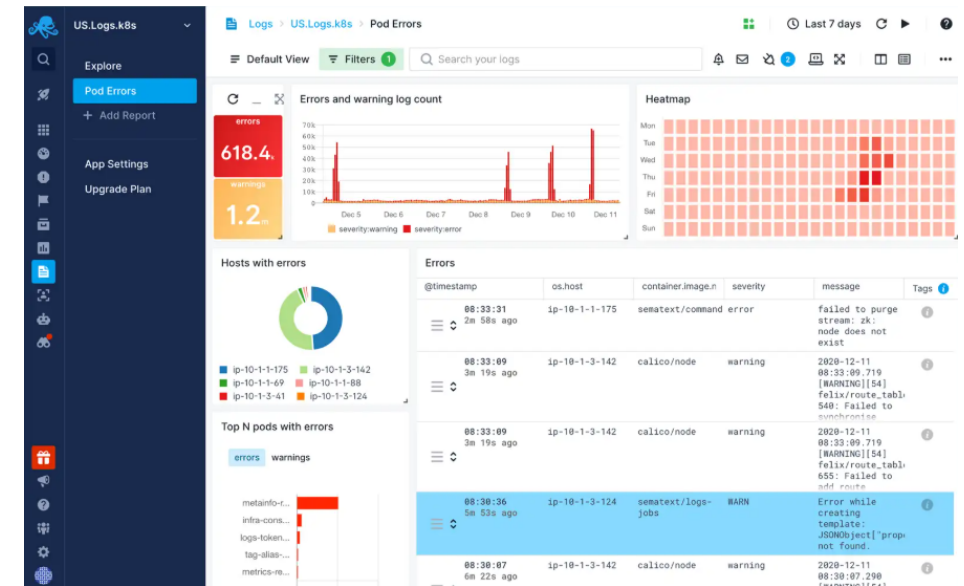
Importancia del Logging y Monitoreo

¿Por qué es importante?

- Permite **detectar ataques en tiempo real**.
- Facilita **auditorías y análisis forenses**.

Errores comunes en Logging

- No registrar intentos de acceso fallidos.
- No monitorear cambios en configuraciones críticas.
- Almacenar logs sin cifrado, exponiéndolos a ataques.



LOGGING & MONITORING

Buenas Prácticas en Logging

¿Qué eventos registrar?

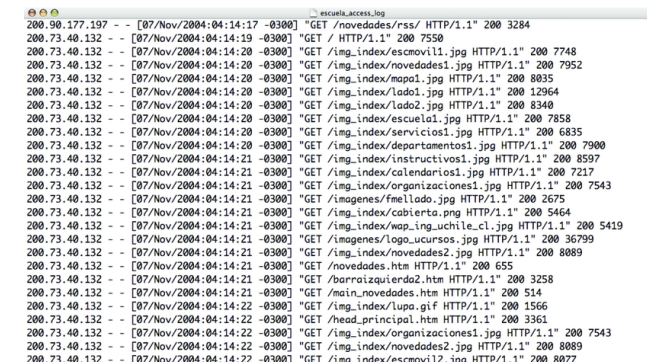
- Intentos de acceso fallidos.
- Acciones administrativas (*creación de usuarios, cambios de permisos*).
- Peticiones sospechosas (*inyecciones SQL, XSS*).

Ejemplo de registro de eventos

```
{  
  "timestamp": "2024-03-06T12:00:00Z",  
  "event": "Failed login attempt",  
  "username": "admin",  
  "ip_address": "192.168.1.100"  
}
```

Mejorando la seguridad de los logs

- Almacenar logs de manera centralizada (*ELK, Splunk*).
- Evitar incluir datos sensibles en registros.
- Monitorear en tiempo real con alertas automatizadas.



```
200.90.177.197 - - [07/Nov/2004:04:14:17 -0300] "GET /novedades/rss/ HTTP/1.1" 200 3284  
200.73.40.132 - - [07/Nov/2004:04:14:19 -0300] "GET / HTTP/1.1" 200 7550  
200.73.40.132 - - [07/Nov/2004:04:14:20 -0300] "GET /img_index/escnovil1.jpg HTTP/1.1" 200 7748  
200.73.40.132 - - [07/Nov/2004:04:14:20 -0300] "GET /img_index/novedades1.jpg HTTP/1.1" 200 7952  
200.73.40.132 - - [07/Nov/2004:04:14:20 -0300] "GET /img_index/nopa1.jpg HTTP/1.1" 200 8835  
200.73.40.132 - - [07/Nov/2004:04:14:20 -0300] "GET /img_index/lado1.jpg HTTP/1.1" 200 12964  
200.73.40.132 - - [07/Nov/2004:04:14:20 -0300] "GET /img_index/lado2.jpg HTTP/1.1" 200 8340  
200.73.40.132 - - [07/Nov/2004:04:14:20 -0300] "GET /img_index/escuela1.jpg HTTP/1.1" 200 7858  
200.73.40.132 - - [07/Nov/2004:04:14:20 -0300] "GET /img_index/servicios1.jpg HTTP/1.1" 200 6835  
200.73.40.132 - - [07/Nov/2004:04:14:20 -0300] "GET /img_index/departamentos1.jpg HTTP/1.1" 200 7900  
200.73.40.132 - - [07/Nov/2004:04:14:21 -0300] "GET /img_index/instructivos1.jpg HTTP/1.1" 200 8597  
200.73.40.132 - - [07/Nov/2004:04:14:21 -0300] "GET /img_index/calendarios1.jpg HTTP/1.1" 200 7217  
200.73.40.132 - - [07/Nov/2004:04:14:21 -0300] "GET /img_index/organizaciones1.jpg HTTP/1.1" 200 7543  
200.73.40.132 - - [07/Nov/2004:04:14:21 -0300] "GET /imagenes/fmellado.jpg HTTP/1.1" 200 2675  
200.73.40.132 - - [07/Nov/2004:04:14:21 -0300] "GET /img_index/cabierto.png HTTP/1.1" 200 5464  
200.73.40.132 - - [07/Nov/2004:04:14:21 -0300] "GET /img_index/wap_ing_uchile.cl.jpg HTTP/1.1" 200 5419  
200.73.40.132 - - [07/Nov/2004:04:14:21 -0300] "GET /imagenes/logo.ucursos.jpg HTTP/1.1" 200 36799  
200.73.40.132 - - [07/Nov/2004:04:14:21 -0300] "GET /img_index/novedades2.jpg HTTP/1.1" 200 8089  
200.73.40.132 - - [07/Nov/2004:04:14:21 -0300] "GET /novedades.htm HTTP/1.1" 200 655  
200.73.40.132 - - [07/Nov/2004:04:14:21 -0300] "GET /barraizquierda2.htm HTTP/1.1" 200 3258  
200.73.40.132 - - [07/Nov/2004:04:14:21 -0300] "GET /main_novedades.htm HTTP/1.1" 200 514  
200.73.40.132 - - [07/Nov/2004:04:14:22 -0300] "GET /img_index/lupa.gif HTTP/1.1" 200 1566  
200.73.40.132 - - [07/Nov/2004:04:14:22 -0300] "GET /head_principal.htm HTTP/1.1" 200 3361  
200.73.40.132 - - [07/Nov/2004:04:14:22 -0300] "GET /img_index/organizaciones1.jpg HTTP/1.1" 200 7543  
200.73.40.132 - - [07/Nov/2004:04:14:22 -0300] "GET /img_index/novedades2.jpg HTTP/1.1" 200 8089  
200.73.40.132 - - [07/Nov/2004:04:14:22 -0300] "GET /img_index/escnovil2.jpg HTTP/1.1" 200 8077
```



LOGGING & MONITORING

Monitoreo de Seguridad en Tiempo Real

Herramientas para monitoreo

- SIEM (Security Information and Event Management): Splunk, Graylog, ELK.
- Monitorización de tráfico: Zeek, Suricata.
- Detección de intrusos: Fail2Ban, Snort.

Ejemplo de Configuración en Fail2Ban (Bloquear intentos de acceso fallidos)

```
[sshd]  
enabled = true  
port = ssh  
filter = sshd  
logpath = /var/log/auth.log  
bantime = 3600  
maxretry = 5
```

Bloquea direcciones IP con **más de 5 intentos fallidos** en 1 hora.





Logging & Monitoring

ACTIVIDAD

M5-A4-Implementación de Logging & Monitoring

Tema: Registro y monitoreo de eventos de seguridad

Objetivo: Implementar un sistema de logging y detección de eventos sospechosos